

Responsible AI Policy

Northstar FinTech Services Pvt. Ltd. (fictional organization, for portfolio purposes)

Prepared by: Nisarg Kamble | AI Governance Portfolio, Project 3 of 5 | September 2026 | Policy Owner: AI Governance Committee

1. Purpose

This policy establishes how Northstar FinTech Services Pvt. Ltd. (“Northstar,” a fictional organization used for portfolio purposes) develops, procures, deploys, and monitors artificial intelligence systems. It translates general responsible-AI principles into specific organizational requirements so that AI risk is managed consistently rather than left to individual teams’ discretion. This policy operationalizes, but does not replace, the risk-assessment methodology described in Northstar’s NIST AI RMF-based governance process (see Project 2 of this portfolio).

2. Scope

This policy applies to all AI systems developed internally or procured from third parties that are used in Northstar’s operations, including but not limited to: customer-service AI, fraud-detection models, marketing personalization tools, employee productivity AI, automated document processing, and any AI system that informs credit-related decisions. It applies to all employees, contractors, and third-party vendors operating on Northstar’s behalf. This policy governs organizational conduct; it does not, on its own, determine whether any specific AI use case complies with applicable law — legal and regulatory compliance is assessed separately by Northstar’s Legal and Compliance functions.

3. Policy Principles

Each principle below is stated with its operational meaning at Northstar, not as an abstract value. Related principles are grouped under a shared heading — this groups eleven operational requirements under four umbrellas, matching how real published corporate AI standards (e.g., Microsoft’s six-principle Responsible AI Standard, IBM’s three-principle/five-pillar framework) tier a broad set of obligations under a smaller number of top-level commitments, without dropping any individual requirement.

3.1 Fairness & Non-Discrimination

Fairness — AI systems must be tested for disparate performance across customer segments before deployment, and material disparities must be documented and reviewed by the AI Governance Committee before go-live. Fairness is treated as a measurable, pre-deployment testing requirement, not an assumed property.

3.2 Transparency & Accountability to Customers

Transparency — Customers are informed when they are interacting with an AI system rather than a human employee, and Northstar maintains internal documentation of each AI system's intended purpose and limitations.

Explainability — For AI systems in the High risk tier (Section 5), Northstar requires the ability to provide a customer-facing explanation of the general basis for an output (explainability) as distinct from requiring full technical interpretability of the underlying model (interpretability), which may not be achievable for all model types.

Contestability — Customers affected by an AI-influenced decision have a defined route to request human review — this is a specific requirement distinct from general customer service, and is tracked as its own metric.

3.3 Accountability & Human Oversight

Accountability — Every AI system in production has a named Business Owner and a named AI Risk Owner (Section 4); accountability is not considered satisfied by the existence of this policy alone.

Human Oversight — Defined further in Section 9 — human oversight is the organizational requirement that a human retains meaningful ability to review, override, or intervene in AI-influenced outcomes, distinct from human-in-the-loop, which refers to the specific workflow mechanism (e.g., an escalation button) that implements this requirement in a given system.

3.4 Privacy & Security

Privacy — AI systems process personal data in accordance with Northstar's Data Governance requirements (Section 7) and applicable law, including India's Digital Personal Data Protection Act, 2023.

Security — AI systems are subject to the same security review process as other production systems, plus AI-specific threats (e.g., prompt injection, model extraction) addressed in Section 8.

3.5 Safety & Robustness

Safety — AI systems are scoped to avoid actions with irreversible or high-severity consequences (e.g., autonomous transaction execution) without a human decision point, consistent with the scope-restriction approach demonstrated in Project 2 of this portfolio.

Robustness — AI systems are tested against edge cases, adversarial inputs, and data-quality degradation before deployment, and monitored for performance drift after deployment.

3.6 Accessibility

Accessibility — Customer-facing AI interfaces must meet Northstar's existing digital accessibility standards; AI is not exempt from accessibility requirements that apply to other customer channels.

4. Roles and Responsibilities

Role	Responsibility
Board / Executive Leadership	Ultimate accountability for AI risk appetite; approves the Responsible AI Policy and reviews material AI incidents.
AI Governance Committee	Cross-functional approval body for new AI use cases; owns risk classification decisions and this policy's maintenance.
Business Owner	Accountable for a specific AI system's performance and business outcomes; first point of escalation.
AI/ML Team	Designs, builds, tests, and documents AI systems in line with this policy's technical requirements.
Security	Assesses and controls security risks specific to AI systems, including adversarial and data-exposure risks.
Privacy / Legal	Reviews data-protection and regulatory implications; interprets applicable law (e.g., DPDP Act, RBI regulation).
Risk	Owns the enterprise AI risk register; monitors residual risk post-deployment.
Procurement	Applies third-party AI vendor due diligence (see Section 11) before contracting.
Internal Audit	Independently verifies that AI governance controls operate as documented.
Employees	Use AI systems within their approved scope; report suspected issues promptly.

5. AI Risk Classification

Northstar classifies AI use cases into four internal tiers to determine the level of governance scrutiny required. This is Northstar's internal governance mechanism only, and is not automatically equivalent to any external legal or regulatory risk classification (for example, the EU AI Act's risk tiers, which apply a different methodology and legal test and are not directly imported into this framework).

Tier	Example	Governance Requirement
Prohibited / Restricted	AI use fully automating credit-approval or adverse-action decisions without human review; AI used to infer protected characteristics not disclosed	Not permitted under this policy.

Tier	Example	Governance Requirement
High	by the customer. AI materially influencing a credit, pricing, or account-status decision; AI processing sensitive personal data at scale.	AI Governance Committee approval required; mandatory pre-deployment testing and human oversight.
Moderate	Customer-facing conversational AI providing information (not decisions); internal AI-assisted document processing.	Business Owner + Risk sign-off; standard testing and monitoring.
Low	Internal productivity tools (e.g., AI-assisted drafting) with no customer-facing output and no sensitive data access.	Business Owner self-assessment against this policy.

6. AI Lifecycle Governance

- **Ideation:** proposed AI use cases are logged with the AI Governance Committee and assigned a preliminary risk tier before any development work begins.
- **Development:** teams follow Northstar's secure-development practices, extended with AI-specific requirements (data lineage documentation, model card creation).
- **Testing:** pre-deployment testing covers functional accuracy, subgroup fairness testing (Moderate tier and above), and adversarial/security testing (High tier).
- **Approval:** sign-off required per the risk-classification table in Section 5 before production deployment.
- **Deployment:** phased rollout preferred over full release for High-tier systems, consistent with a pilot-first approach.
- **Monitoring:** ongoing performance and fairness monitoring per Section 8, at a cadence proportional to risk tier.
- **Change Management:** material changes to an AI system's model, data sources, or scope trigger re-assessment against Section 5, not a one-time approval that persists indefinitely.
- **Retirement:** decommissioned AI systems have a documented data-retention and deletion plan consistent with Section 7.

7. Data Governance

- **Data quality:** training and reference data must be reviewed for accuracy and representativeness before use in a High-tier AI system.
- **Data provenance:** the source and collection basis of data used by an AI system must be documented and traceable.
- **Privacy:** personal data used in AI systems is subject to Northstar's Privacy Policy and applicable law, including the DPDP Act's requirements as they come into force.

- **Access:** data access for AI systems follows least-privilege principles — an AI system is provisioned only the data fields required for its defined function.
- **Retention:** AI-related data (including conversation logs) is retained per Northstar's data-retention schedule, not indefinitely by default.
- **Sensitive data:** use of sensitive personal data (financial account details, identity documents) in AI systems requires Privacy/Legal sign-off regardless of risk tier.

8. Model / System Governance

- **Validation:** models are validated against defined performance and fairness benchmarks before deployment.
- **Testing:** includes both functional testing (does it work) and adversarial testing (can it be manipulated) as distinct exercises.
- **Performance monitoring:** production performance is compared against validation-stage benchmarks on an ongoing basis to detect drift.
- **Security:** AI-specific security review includes prompt-injection resistance and data-leakage testing, in addition to standard application-security review.
- **Version control:** model and prompt/configuration changes are versioned and auditable.
- **Documentation:** each production AI system has a maintained model card or system card describing intended use, known limitations, and testing history.

9. Human Oversight

Human review is mandatory, not optional, for: any AI output that would result in an adverse action against a customer (e.g., a declined service); any AI-influenced decision in the High risk tier; and any case where an AI system itself flags low confidence in its output. Human oversight is implemented differently depending on system design — for a real-time conversational agent, this takes the form of a human-in-the-loop escalation path (Project 2, Section 7); for a batch fraud-detection model, it takes the form of human review of flagged cases before action is taken. Both implement the same underlying human-oversight principle through different mechanisms appropriate to the system.

10. Incident Management

- **Identification:** any employee, customer complaint, or automated monitoring alert can trigger incident identification.
- **Escalation:** suspected AI incidents are escalated to the AI Risk Owner within 24 hours, consistent with Project 2's governance structure.
- **Containment:** the AI Governance Committee has authority to suspend an AI system's operation pending investigation.
- **Investigation:** root-cause analysis distinguishes between a model-behavior issue, a data issue, and a scope/process failure.
- **Remediation:** corrective action is tracked to completion, including customer remediation where applicable.
- **Documentation and lessons learned:** incidents are logged in Northstar's AI risk register and reviewed at the AI Governance Committee's regular cadence.

11. Third-Party AI

AI systems or components procured from external vendors are subject to Procurement's vendor due-diligence process (see Project 4 of this portfolio for the applicable questionnaire), in addition to, not instead of, the risk classification and lifecycle governance requirements in Sections 5 and 6. A vendor's own certifications (e.g., ISO/IEC 42001, SOC 2) are treated as useful evidence of vendor maturity, not as a substitute for Northstar's own testing and risk assessment of how the vendor's AI performs in Northstar's specific use case.

12. Employee Responsibilities

- Use AI systems only for their approved, documented purpose.
- Do not input customer personal data into general-purpose AI tools that have not been approved through this policy's governance process.
- Report suspected AI errors, unexpected behavior, or potential harm promptly, without fear of blame for having encountered the issue.
- Complete AI-literacy training relevant to their role before using or overseeing an AI system.

13. Exceptions

Exceptions to this policy require written approval from the AI Governance Committee, must be time-bound, and must include a documented risk rationale. Exceptions are logged in the AI risk register and reviewed at each policy review cycle (Section 15).

14. Enforcement

Non-compliance with this policy is addressed through Northstar's standard employee conduct and vendor-management processes. Deployment of an AI system without required approval under Section 5 or 6 is treated as a policy violation regardless of the system's actual risk level, since the approval process itself is how risk level is determined.

15. Review Cycle

This policy is reviewed at least annually by the AI Governance Committee, and on an ad hoc basis following any material AI incident, significant regulatory change (e.g., DPDP Act provisions coming into force), or material change in Northstar's AI use.

16. References

- National Institute of Standards and Technology. (2023). *AI Risk Management Framework (AI RMF 1.0)*.
- International Organization for Standardization / International Electrotechnical Commission. (2023). *ISO/IEC 42001:2023 — Information technology — Artificial intelligence — Management system*. Note: ISO/IEC 42001 certification demonstrates a certified AI management process; it does not, on its own, establish compliance with any specific external AI regulation.

- Ministry of Electronics and Information Technology, Government of India. *Digital Personal Data Protection Act, 2023*, and *DPDP Rules, 2025* (staged commencement; substantive obligations effective 13 May 2027).
- Reserve Bank of India. *RBI (NBFC — Outsourcing of IT Services) Directions, 2025*; *RBI (NBFC — Cybersecurity, Technology Risk, Resilience and Assurance) Directions, 2026*; *RBI Digital Lending Directions, 2025* — direct legal review required for specific applicability to a given use case.

Note on evidence verification: This policy’s principle set was benchmarked against Microsoft’s Responsible AI Standard, IBM’s Principles for Trust and Transparency / Pillars of Trust, and Google’s current AI Principles structure in September 2026 (see 01_Research/benchmarking_notes.md). The RBI reference in this section was upgraded from a generic description to three specific, named, dated regulations, consistent with the same finding in Project 2 of this portfolio.